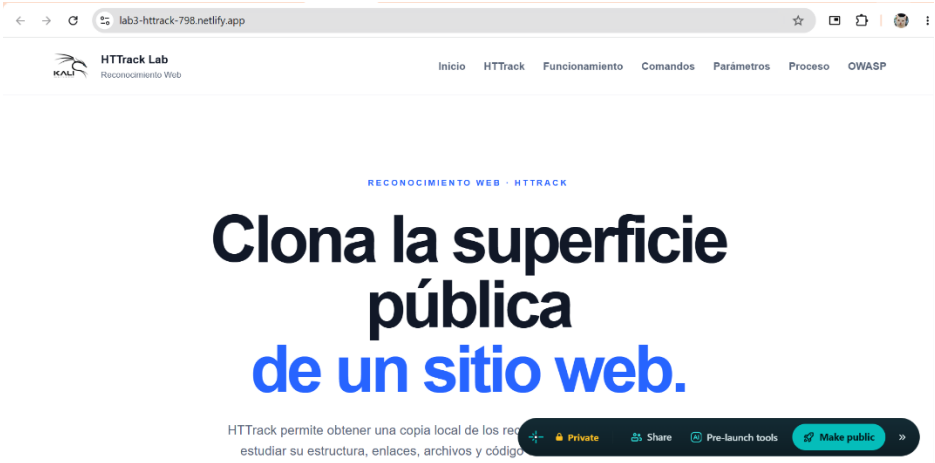
Laboratorio No. 3

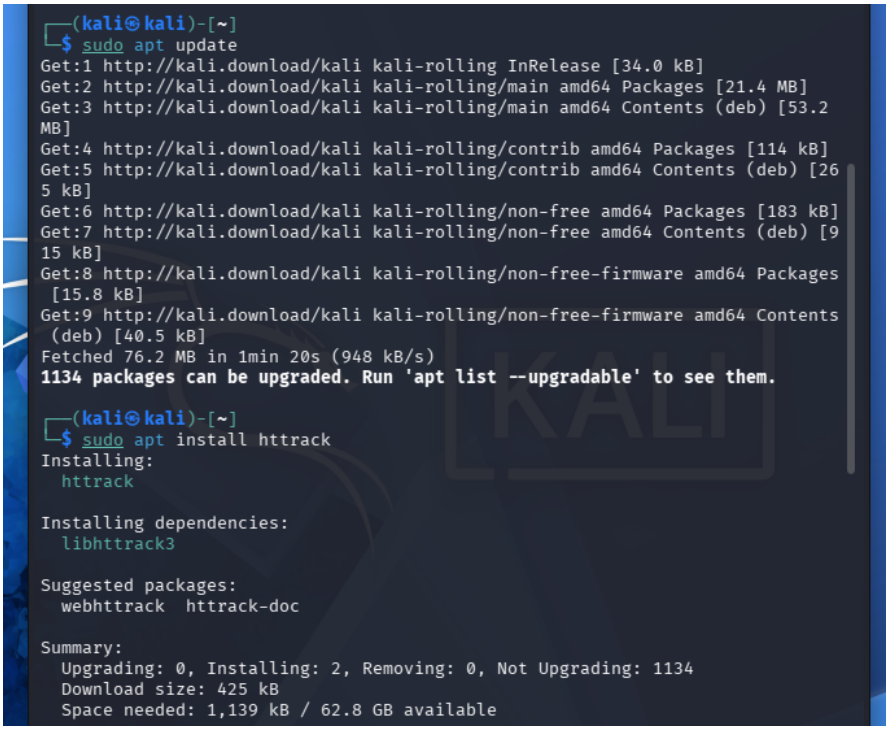
Clonación controlada de un sitio web con HTTrack y análisis de exposición

Publicación del proyecto:



Enlace: https://lab3-httrack-798.netlify.app/

Abrir la terminal e instalar HTTrack



```
┌──(kali㉿kali)-[~]
└─$ whoami
kali

┌──(kali㉿kali)-[~]
└─$ httrack --version
HTTrack version 3.49-14

┌──(kali㉿kali)-[~]
└─$
```

Crear la carpeta del laboratorio

```
┌──(kali㉿kali)-[~]
└─$ cd ~

┌──(kali㉿kali)-[~]
└─$ pwd
/home/kali

┌──(kali㉿kali)-[~]
└─$
```

```
┌──(kali㉿kali)-[~]
└─$ mkdir lab3_httrack

┌──(kali㉿kali)-[~]
└─$ cd lab3_httrack

┌──(kali㉿kali)-[~/lab3_httrack]
└─$ pwd
/home/kali/lab3_httrack

┌──(kali㉿kali)-[~/lab3_httrack]
└─$
```

Ejecutar HTTrack

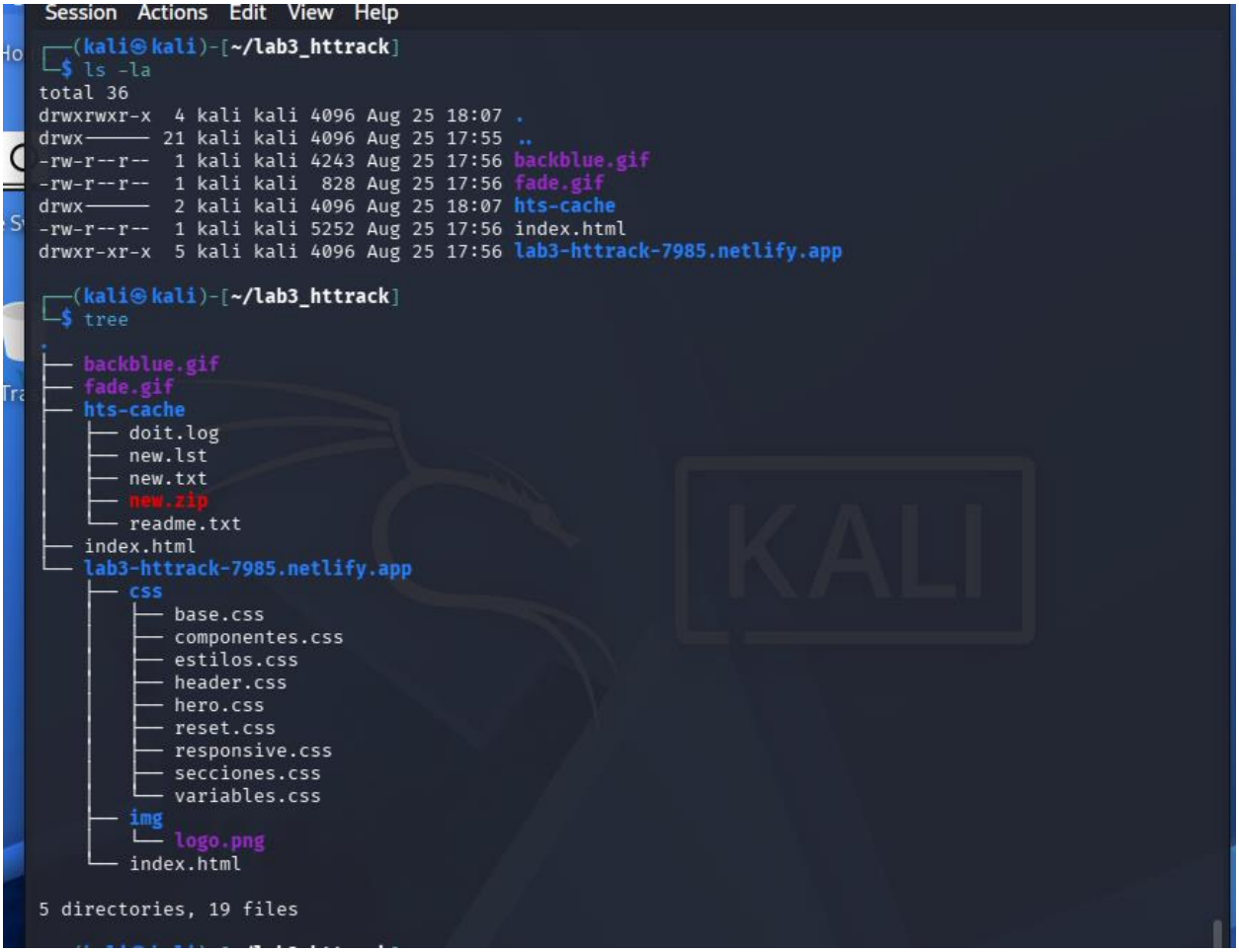
```
┌──(kali㉿kali)-[~/lab3_httrack]
└─$ httrack "https://lab3-httrack-798.netlify.app/ " \
-O "$HOME/lab3_httrack" \
"+*.netlify.app/*" \
"+*.css" \
"+*.js" \
"+*.png" \
"+*.jpg" \
"+*.jpeg" \
"+*.gif" \
-v
There is an index.html and a hts-cache folder in the directory /home/kali/lab
3_httrack/
A site may have been mirrored here, that could mean that you want to update i
t
Be sure parameters are ok

Press <Y><Enter> to confirm, <N><Enter> to abort
y
HTTrack3.49-14 launched on Tue, 25 Aug 2026 21:15:05 at https://lab3-httrack-
798.netlify.app/%20 +*.netlify.app/* +*.css +*.js +*.png +*.jpg +*.jpeg +*.gi
f
(httrack "https://lab3-httrack-798.netlify.app/ " -O /home/kali/lab3_httrack
+*.netlify.app/* +*.css +*.js +*.png +*.jpg +*.jpeg +*.gif -v )

Information, Warnings and Errors reported for this mirror:
note:   the hts-log.txt file, and hts-cache folder, may contain sensitive inf
ormation,
        such as username/password authentication for websites mirrored in thi
s project
        do not share these files/folders if you want these information to rem
ain private

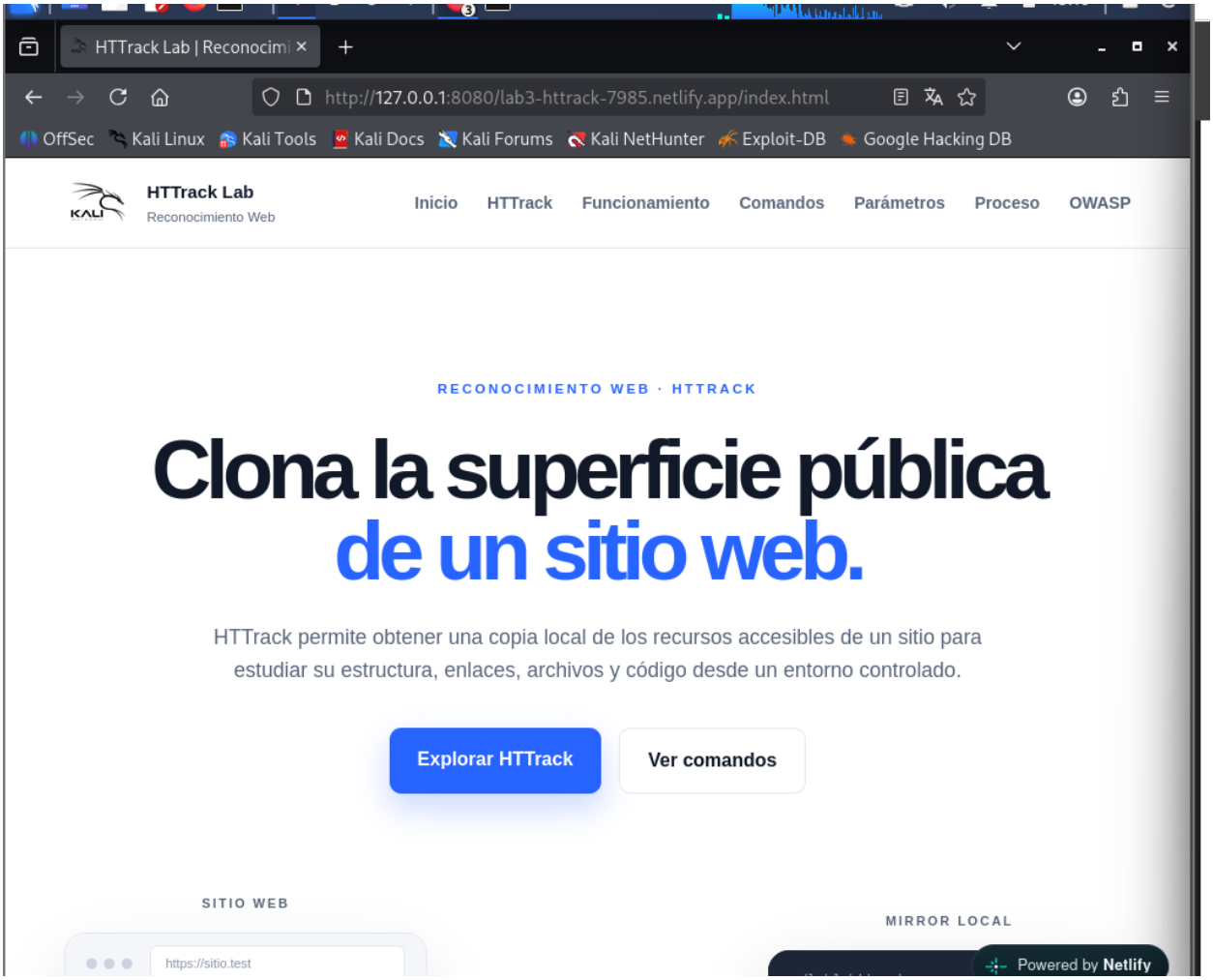
Mirror launched on Tue, 25 Aug 2026 21:15:05 by HTTrack Website Copier/3.49-1
4 [XR&CO'2014]
mirroring https://lab3-httrack-798.netlify.app/%20 +*.netlify.app/* +*.css +*
.js +*.png +*.jpg +*.jpeg +*.gif with the wizard help..
21:15:06ps://labError: c"Unauthorized" (401) at link https://lab3-httrack-798
.netlify.app/  (from primary/primary)
21:15:06        Warning:        No data seems to have been transferred during
 this session! : restoring previous one!
Done.
Thanks for using HTTrack!
```

En la imagen se observa la ejecución del comando **HTTrack** para clonar un sitio web. El programa se conectó a la página y descargó exitosamente todos sus recursos (archivos HTML, estilos CSS, scripts JS y todas las imágenes), guardando una copia exacta y funcional en la carpeta local /home/kali/lab3_httrack para que se pueda explorar el sitio sin necesidad de conexión a internet.



La imagen comprueba el éxito de la clonación del sitio web. Mediante los comandos ls -la y tree, se visualiza de forma jerárquica la estructura de carpetas y archivos que fueron descargados y guardados localmente en el equipo para su análisis.

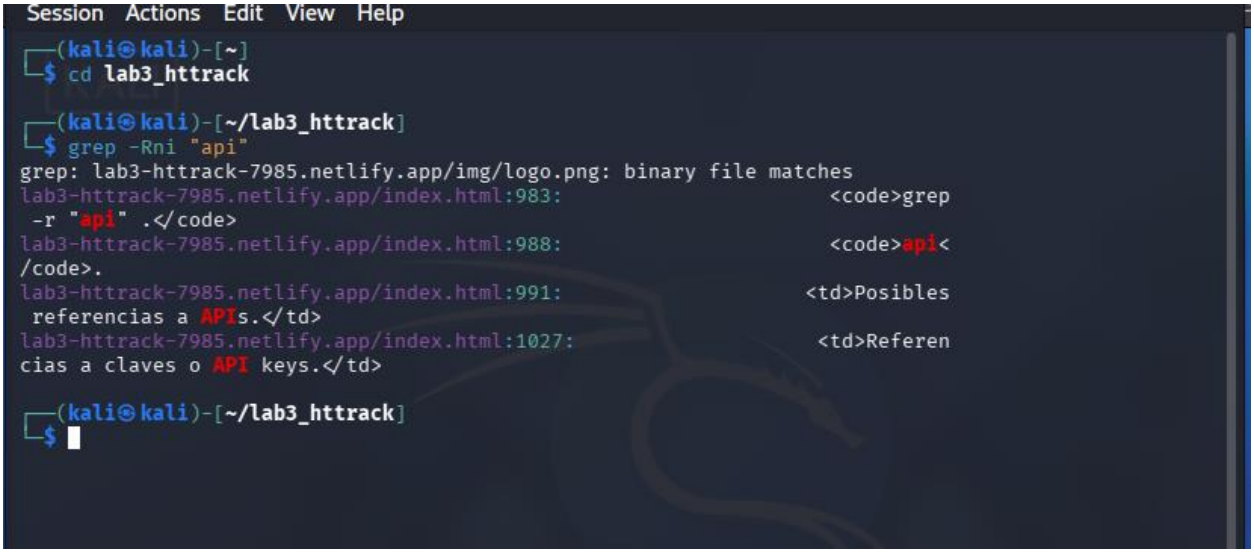




La imagen evidencia el resultado exitoso de la clonación del sitio web. Al observar la barra de direcciones (127.0.0.1), se confirma que la página se está alojando y ejecutando de manera local en el equipo, sin depender de la conexión al servidor original. Asimismo, la visualización intacta de la interfaz, colores y botones demuestra que HTTrack descargó correctamente todos los recursos de diseño y estructura (como hojas de estilo e imágenes), cumpliendo con el objetivo de obtener una copia funcional para su análisis fuera de línea.

Análisis White Hat

grep -Rni "api"



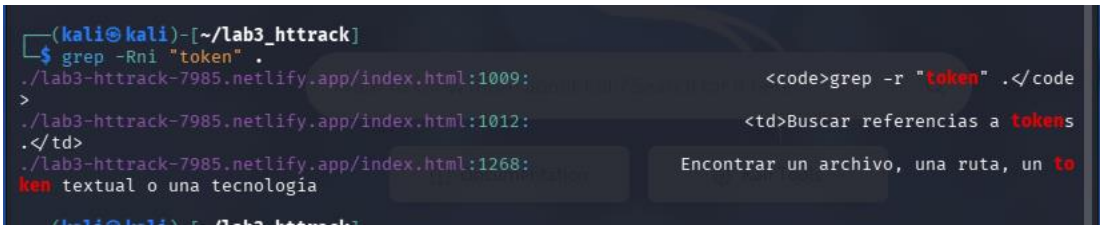
La imagen documenta la fase de análisis de los archivos clonados mediante el uso del comando **grep**. Al ejecutar la instrucción grep -Rni "api", se realiza una búsqueda profunda (recursiva, enumerada e insensible a mayúsculas) en todos los directorios descargados para rastrear cualquier mención de la palabra "api". Los resultados evidencian que la herramienta localizó con éxito el término dentro del código fuente del archivo index.html (específicamente en las líneas 983, 988, 991 y 1027), destacando texto que hace referencia a posibles APIs y claves de acceso (API keys). Este paso demuestra cómo se puede auditar rápidamente el código de la copia local para descubrir información sensible o endpoints ocultos en la estructura del sitio web.

grep -Rni "fetch" .



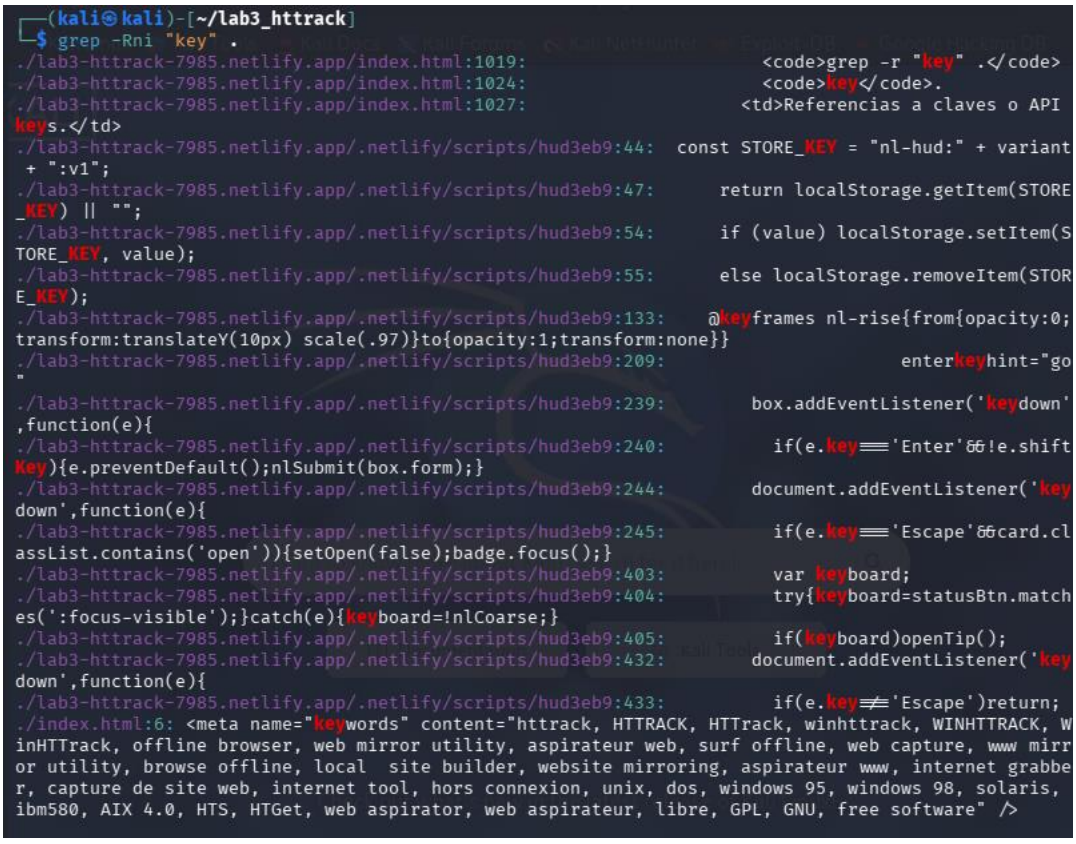
El propósito de este comando es buscar la palabra "fetch" dentro de todos los archivos descargados. En la programación de páginas web, este término se usa de forma común para solicitar información a otros servidores a través de internet. Los resultados en la terminal indican que la palabra fue encontrada en las líneas 996 y 1001 del archivo index.html. Rastrear esta palabra ayuda a identificar en qué partes exactas del código el sitio web intenta comunicarse con el exterior.

grep -Rni "token" .



Posteriormente, se ejecuta el comando grep -Rni "token" .. En esta ocasión, la búsqueda se enfoca en la palabra "token", la cual suele estar relacionada con permisos de acceso, manejo de sesiones y medidas de seguridad. El sistema muestra que el término aparece en las líneas 1009, 1012 y 1268 del mismo archivo index.html. La revisión de esta palabra es útil para comprobar si la página dejó a la vista alguna credencial o dato de seguridad importante de manera accidental entre su código fuente.

grep -Rni "key" .

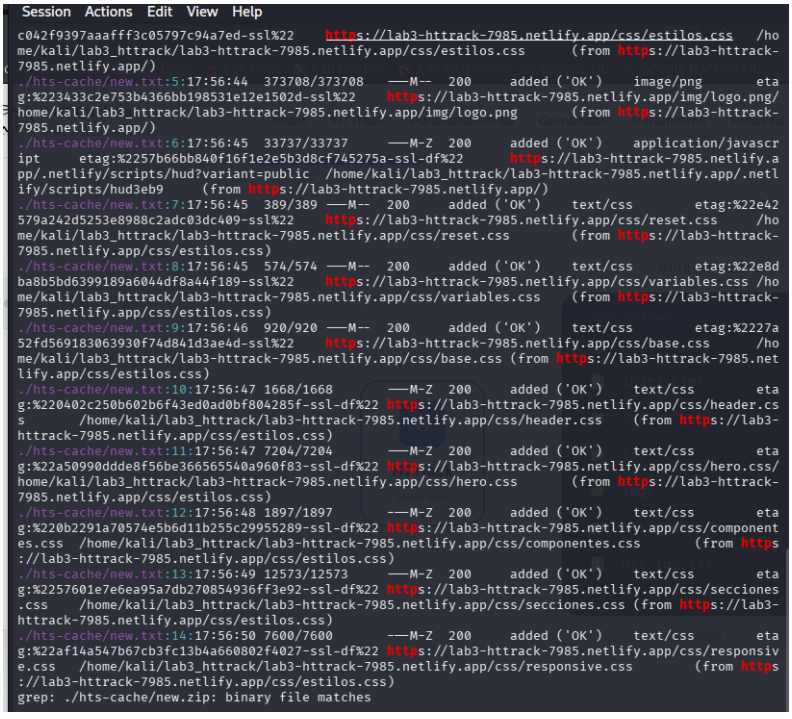


El resultado de este comando se refleja en como la terminal muestra una extensa lista de coincidencias con la palabra “key” tanto en el archivo principal como en diversos scripts internos de la página. Entre los hallazgos se pueden notar referencias directas a claves de acceso (API keys), así como variables de programación (STORE_KEY) y eventos relacionados con el teclado del usuario (keydown). Esta acción se lleva a cabo para comprobar si el sitio expone accidentalmente alguna

credencial de seguridad o contraseña importante entre su código, aunque en el proceso también es normal capturar términos técnicos inofensivos propios de la construcción del sitio web.

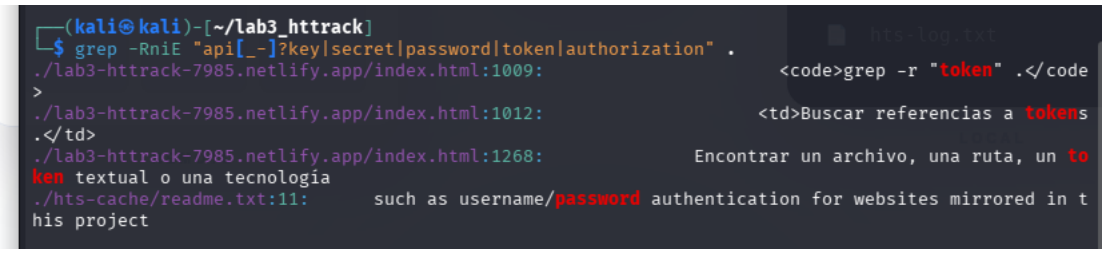
grep -Rni "http" .





La terminal despliega una larga lista de resultados que evidencian enlaces y referencias a "http" y "https" ubicados en el código principal (index.html), en scripts internos de la página y en los registros de funcionamiento de HTTrack. Esta exploración es un paso fundamental en el análisis del sitio, ya que permite descubrir rápidamente direcciones de internet ocultas, conexiones a otros servidores o rutas externas que la página web utiliza para operar.

grep -RniE "api[_ -]?key|secret|password|token|authorization" .



Al añadir la opción -E, se le indica a la terminal que rastree simultáneamente una lista de varias palabras clave críticas para la seguridad, como contraseñas, secretos, tokens y autorizaciones. Los resultados arrojados en pantalla muestran que la herramienta detectó exitosamente la palabra "token" en el código de la página principal y la palabra "password" dentro de un documento de texto interno. Esta técnica es muy útil durante una auditoría, ya que permite revisar de un solo vistazo si los archivos clonados exponen cualquier tipo de credencial o información confidencial.

Registro de los hallazgos

Hallazgo (Término)	Archivo / Ubicación	Clasificación	Justificación
"api"	index.html	Informativo	Es texto descriptivo y comandos de ejemplo dentro de etiquetas HTML, no una clave real.
"fetch"	index.html	Informativo	Muestra comandos de búsqueda documentados en la página, no llamados a servidores.
"token"	index.html	Informativo	Es texto explicativo sobre cómo buscar tokens en la web, no un token expuesto.

Hallazgo (Término)	Archivo / Ubicación	Clasificación	Justificación
"key"	scripts/..., index.html	Configuración pública	Referencias a eventos de teclado (e.key), variables locales y etiquetas <meta>, normales en el frontend.
"http"	index.html, scripts/...	Configuración pública	Son URLs estándar, enlaces externos y rutas necesarias para el funcionamiento público del sitio.
"password"	hts-cache/readme.txt	Informativo	Es texto genérico de la documentación (Readme) de la herramienta HTTrack, no credenciales del sistema.

Responder las preguntas:

1. **¿Se encontró información sensible?**
   No, las búsquedas solamente revelaron texto descriptivo en el HTML, documentación genérica y eventos o variables de la interfaz gráfica. No se mostraron credenciales reales ni datos privados.

2. **¿Qué información del sitio fue posible reconstruir?**
   Se logró reconstruir toda la capa pública del frontend: HTML, CSS, Scripts, recursos multimedia y la estructura de enlaces internos y externos

3. **¿Se encontraron endpoints o llamadas HTTP?**
   Sí, se encontraron referencias a URLs, pero no de una API backend interna crítica.

4. **¿Existe información que debería trasladarse al backend?**
   No se detectaron secretos expuestos, sin embargo, si el sitio llegara a manejar tokens de acceso reales o API Keys de servicios de terceros (como bases de datos o pasarelas de pago), estos nunca deben estar presentes en el código del frontend ni en el HTML, sino que deben gestionarse exclusivamente desde el backend.
5. **¿Qué controles de seguridad implementaríamos?**
   Para proteger el sitio contra el análisis y la clonación automatizada mediante herramientas como HTTrack, la primera línea de defensa sería configurar un WAF (Web Application Firewall) y políticas de *Rate Limiting* en el servidor para identificar y bloquear *User-Agents*

sospechosos o solicitudes masivas. Además, es fundamental minificar y ofuscar el código JavaScript para dificultar cualquier intento de ingeniería inversa